

Network Defense & Countermeasures — Interview Checklist

Organized by **interview priority tier**; within each tier, topics are grouped by domain so related concepts stay together.

- **Priority 1 — Must Know:** Very commonly asked. Explain clearly with examples.
- **Priority 2 — Important:** Often asked as follow-up or practical questions.
- **Priority 3 — Good to Know:** Useful for deeper technical rounds and extra advantage.

For every **Priority 1** topic, prepare four things: **What is it?** → **How does it work?** → **Why is it used?** → **One real/practical example.**

Completion Checklist

Notes Written

- ☒ Security Fundamentals (01 - Security Fundamentals.md)
- ☒ Firewalls (02 - Firewalls.md)
- ☒ DMZ (03 - DMZ.md)
- ☒ iptables + NAT + Fail2ban + GeoIP (04 - iptables.md)
- ☐ IDS / IPS / Snort / Suricata / OSSEC
- ☐ VPN / IPsec / OpenVPN
- ☐ Wireshark / tcpdump
- ☐ DoS / DDoS
- ☐ Reverse Proxy / Load Balancing / Nginx
- ☐ SIEM / SOC / ELK / Syslog / Nagios
- ☐ Incident Response / Threat Hunting / MITRE ATT&CK

Topic Revision (tick when you can explain each from memory)

Priority 1

- ☒ Information Security — meaning and purpose
- ☒ CIA Triad — Confidentiality, Integrity, Availability
- ☒ Security vs Privacy
- ☒ Vulnerability / Threat / Risk — definitions and relationship
- ☒ Attack Vector / Attack Surface / Exposure
- ☒ Countermeasure / Risk Management
- ☒ Security Controls — Preventive / Detective / Corrective
- ☒ Server Hardening
- ☒ Defence in Depth
- ☒ Firewall — what, how, rules
- ☒ Packet Filtering Firewall
- ☒ Stateless Firewall

- ☒ Stateful Firewall + connection tracking
- ☒ Stateful vs Stateless
- ☒ NGFW + DPI + Application Control
- ☒ Traditional Firewall vs NGFW
- ☒ Proxy Firewall
- ☒ Host Firewall vs Network Firewall
- ☒ Default Allow vs Default Deny
- ☒ Inbound vs Outbound rules
- ☒ DMZ — what, why, placement
- ☒ Web server in DMZ
- ☒ Database should not be directly exposed
- ☒ Internet → DMZ rules
- ☒ DMZ → Internal rules
- ☒ Internal → DMZ rules
- ☒ iptables — what, Netfilter, basic structure
- ☒ Tables — filter / nat / mangle / raw / security
- ☒ Chains — INPUT / OUTPUT / FORWARD / PREROUTING / POSTROUTING
- ☒ Rules — match conditions + targets
- ☒ Targets — ACCEPT / DROP / REJECT
- ☒ Rule processing order + default policy
- ☒ Connection tracking — NEW / ESTABLISHED / RELATED / INVALID
- ☒ NAT — SNAT / DNAT / PAT / MASQUERADE
- ☒ Port Forwarding
- ☒ IP Forwarding
- ☒ Fail2ban — jails / maxretry / findtime / bantime
- ☒ Fail2ban firewall integration
- ☒ GeoIP Blocking — Xtables-Addons, limitations
- ☐ IDS / IPS — what, how, passive vs inline
- ☐ IDS vs IPS
- ☐ NIDS vs HIDS
- ☐ Signature-based vs Anomaly-based detection
- ☐ False Positive vs False Negative
- ☐ Snort — NIDS mode, rule structure
- ☐ Suricata — IDS/IPS modes, multi-threading
- ☐ VPN — encryption, tunneling, auth
- ☐ Remote Access VPN vs Site-to-Site VPN
- ☐ Full Tunnel vs Split Tunnel
- ☐ IPsec — AH vs ESP
- ☐ IPsec — Tunnel Mode vs Transport Mode
- ☐ OpenVPN — certificates, client/server model
- ☐ Wireshark — capture/display filters, protocol analysis
- ☐ TCP Three-Way Handshake
- ☐ tcpdump — interface capture, filters, .pcap
- ☐ DoS vs DDoS — types, SYN Flood, HTTP Flood
- ☐ DDoS Mitigation — layers 3/4/7, CDN, scrubbing
- ☐ Reverse Proxy — Nginx, hide backends, TLS termination

- ☐ Forward Proxy vs Reverse Proxy
- ☐ Load Balancer — health checks, high availability
- ☐ SIEM — collection, normalization, correlation, alerts
- ☐ SOC Workflow — triage → investigation → containment
- ☐ Security Logs — firewall / IDS / auth / system / web / VPN
- ☐ Incident Response — 6 phases
- ☐ Threat Hunting — hypothesis → collect → investigate → detect
- ☐ MITRE ATT&CK — tactics and techniques

● Priority 2

- ☐ Security Event vs Alert vs Incident
- ☐ QoS — bandwidth / latency / jitter / packet loss
- ☐ Blast Radius / Network Segmentation / Three-Tier Architecture
- ☐ UTM vs NGFW
- ☐ IPv6 firewall rules / iptables
- ☐ Rate Limiting
- ☐ VPN Protocols — PPTP / SSTP / L2TP / RRAS
- ☐ VPN Attacks and Misconfiguration
- ☐ IDS Architecture — sensor / agent / manager
- ☐ Intruder Types — Masquerader / Misfeasor / Clandestine
- ☐ Traditional vs Distributed Attacks
- ☐ SSL/TLS Termination / Server Farming
- ☐ WAF vs Firewall
- ☐ ELK Stack — Elasticsearch / Logstash / Kibana
- ☐ Syslog — centralized logging and forwarding
- ☐ Nagios — infrastructure monitoring vs SIEM vs IDS

● Priority 3

- ☐ NIST Cybersecurity Framework
- ☐ OWASP Top 10 — risk perspective
- ☐ Security Breach Case Study analysis
- ☐ Firewall Misconfiguration examples
- ☐ Firewall Automation — risks and benefits
- ☐ Kerberos / TLS packet analysis
- ☐ Suspicious packet patterns
- ☐ Honeypot vs HoneyNet
- ☐ IDS Evasion techniques and mitigations
- ☐ Security Event Severity levels
- ☐ Threat Intelligence — IOC / IOA
- ☐ QoS + DDoS impact analysis

🎯 Scenarios

- ☒ Security Fundamentals scenarios
- ☒ Firewall scenarios

- ☒ DMZ scenarios
- ☒ iptables scenarios
- ☒ NAT / Port Forwarding scenarios
- ☒ Fail2ban scenarios
- ☒ GeoIP scenarios
- ☐ IDS / IPS scenarios
- ☐ VPN / IPsec scenarios
- ☐ Wireshark / tcpdump scenarios
- ☐ DoS / DDoS scenarios
- ☐ Reverse Proxy / Load Balancer scenarios
- ☐ SIEM / SOC scenarios
- ☐ Threat Hunting / MITRE ATT&CK scenarios

Practical / Lab

- ☒ iptables lab questions
- ☐ Wireshark lab
- ☐ tcpdump lab
- ☐ Fail2ban lab (*covered in notes*)
- ☐ Nginx / Squid lab
- ☐ OpenVPN lab
- ☐ Snort lab
- ☐ Suricata lab
- ☐ OSSEC lab
- ☐ ELK lab
- ☐ Syslog / SIEM lab
- ☐ Nagios lab

Priority 1 — Must Know

Security Fundamentals

- ☐ Information Security — meaning and purpose
- ☐ CIA Triad — Confidentiality, Integrity, Availability
- ☐ Vulnerability — weakness in a system
- ☐ Threat — something that can exploit a weakness
- ☐ Risk — probability + impact of a threat
- ☐ Attack Vector — path used by attacker
- ☐ Attack Surface — total exposed points
- ☐ Exposure — how much a system is exposed
- ☐ Countermeasure — security control used against risk
- ☐ Risk Management — identify, assess, treat, monitor
- ☐ Security Control — preventive, detective, corrective
- ☐ Defence in Depth — multiple security layers
- ☐ Vulnerability vs Threat vs Risk

Must-know relationship:

Threat + Vulnerability → Risk → Countermeasure

Example:

Open SSH port + weak password → brute-force risk → MFA + firewall + Fail2ban

Firewalls

- ☐ What is a Firewall?
- ☐ How Firewall works
- ☐ Firewall rules
- ☐ Packet Filtering Firewall
- ☐ Stateful Firewall
- ☐ Stateless Firewall
- ☐ Stateful vs Stateless Firewall
- ☐ Next Generation Firewall (NGFW)
- ☐ Traditional Firewall vs NGFW
- ☐ Proxy Firewall
- ☐ Host Firewall vs Network Firewall
- ☐ Default Allow vs Default Deny
- ☐ Inbound vs Outbound rules

Stateless:

Packet → Check IP/Port/Protocol → Allow/Drop

Stateful:

Packet → Check Connection State → Check Rules → Allow/Drop

Firewall Type	Layer	Notes
Packet Filtering	L3/L4	Usually stateless, fast
Stateful Inspection	L3/L4	Tracks connection state
NGFW	L3-L7	Application-aware, DPI, IPS
Proxy/Application Firewall	L7	Application-level inspection

DMZ

- ☐ What is DMZ?
- ☐ Why DMZ is used
- ☐ Where DMZ is placed
- ☐ Web server in DMZ
- ☐ Why DB should not be directly exposed
- ☐ Internet → DMZ firewall rules

- ☐ DMZ → Internal firewall rules
- ☐ Internal → DMZ firewall rules

```
Internet
  ↓
Firewall
  ↓
DMZ
  ↓
Web Server
  ↓
Internal Firewall
  ↓
Application / Database Servers
```

iptables

- ☐ What is iptables?
- ☐ Netfilter
- ☐ Tables
- ☐ Chains
- ☐ Rules
- ☐ Targets
- ☐ Rule processing order
- ☐ Default policy
- ☐ ACCEPT
- ☐ DROP
- ☐ REJECT
- ☐ Connection tracking

Main Chains

Chain	Purpose
INPUT	Traffic destined for local machine
OUTPUT	Traffic generated by local machine
FORWARD	Traffic routed through the machine

Main Tables

Table	Purpose
filter	Packet filtering
nat	NAT and port forwarding
mangle	Packet modification

Table	Purpose
raw	Connection tracking exceptions
security	Security policies

NAT & Port Forwarding

- ☐ NAT
- ☐ SNAT
- ☐ DNAT
- ☐ PAT
- ☐ MASQUERADE
- ☐ Port Forwarding
- ☐ IP Forwarding
- ☐ Internet Sharing

```

Internet
  ↓
Public-IP:80
  ↓
Firewall
  ↓
DNAT
  ↓
192.168.1.10:80

```

IDS / IPS

- ☐ What is IDS?
- ☐ What is IPS?
- ☐ IDS vs IPS
- ☐ Passive deployment
- ☐ Inline deployment
- ☐ NIDS
- ☐ HIDS
- ☐ Signature-based detection
- ☐ Anomaly-based detection
- ☐ False Positive
- ☐ False Negative

IDS vs IPS

IDS	IPS
Detects attacks	Detects and blocks attacks

IDS	IPS
Usually passive	Usually inline
Generates alerts	Can drop malicious traffic
Monitoring	Prevention

NIDS vs HIDS

NIDS	HIDS
Network traffic	Host activity
Monitors packets	Monitors logs/files/processes
Network sensor	Installed on host
Example: Snort	Example: OSSEC

Signature vs Anomaly

Signature Based	Anomaly Based
Detects known attacks	Detects unusual behavior
Uses known signatures	Uses baseline/behavior
Lower false positives	May have more false positives
Difficult with unknown attacks	Can detect new/unknown behavior

Snort

- ☐ What is Snort?
- ☐ Snort as NIDS
- ☐ Packet inspection
- ☐ Signature-based detection
- ☐ Snort alerts
- ☐ Snort sensors
- ☐ Snort rule structure

Example:

```
alert tcp any any -> any 80 (msg:"HTTP Traffic"; sid:1000001;)
```

Know:

- Action
- Protocol
- Source IP

- Source Port
- Direction
- Destination IP
- Destination Port
- Rule Options
- SID

Suricata

- ☐ What is Suricata?
- ☐ IDS mode
- ☐ IPS mode
- ☐ Rules/signatures
- ☐ Packet inspection
- ☐ Inline blocking
- ☐ Suricata vs Snort
- ☐ Multi-threading

VPN

- ☐ What is VPN?
- ☐ Why VPN is used
- ☐ Encryption
- ☐ Authentication
- ☐ Integrity
- ☐ Tunneling
- ☐ Remote Access VPN
- ☐ Site-to-Site VPN
- ☐ Full Tunnel
- ☐ Split Tunnel

```
Office A
  ↓
VPN Gateway
  ↓
===== Encrypted Tunnel =====
  ↓
VPN Gateway
  ↓
Office B
```

VPN Type	Purpose
Remote Access VPN	User connects to organization
Site-to-Site VPN	Connects two networks

VPN Type	Purpose
Full Tunnel	All traffic goes through VPN
Split Tunnel	Only selected traffic uses VPN

IPsec

- ☐ What is IPsec?
- ☐ Encryption
- ☐ Authentication
- ☐ Integrity
- ☐ AH
- ☐ ESP
- ☐ Tunnel Mode
- ☐ Transport Mode

AH

Authentication Header:

- Authentication
- Integrity
- No encryption

ESP

Encapsulating Security Payload:

- Encryption
- Authentication
- Integrity

Transport vs Tunnel Mode

Transport Mode	Tunnel Mode
Protects IP payload	Protects entire original IP packet
Original header remains	New IP header added
Common host-to-host	Common gateway-to-gateway

OpenVPN

- ☐ OpenVPN architecture
- ☐ Client/server model
- ☐ TLS-based security
- ☐ Certificates
- ☐ Authentication

- ☐ Remote-access VPN
- ☐ Site-to-site VPN

Wireshark & Traffic Analysis

- ☐ Packet capture
- ☐ Packet analysis
- ☐ Capture filter
- ☐ Display filter
- ☐ TCP packets
- ☐ UDP packets
- ☐ DNS packets
- ☐ HTTP packets
- ☐ TLS packets
- ☐ ICMP packets
- ☐ TCP handshake

Capture Filter vs Display Filter

Capture Filter	Display Filter
Applied before capture	Applied after capture
Controls what is captured	Controls what is displayed

Example display filters:

```
tcp
http
dns
icmp
ip.addr == 192.168.1.10
tcp.port == 443
```

TCP Three-Way Handshake

```
Client                                Server
SYN ----->
      <----- SYN-ACK
ACK ----->
```

Know:

- SYN
- SYN-ACK
- ACK
- TCP flags

tcpdump

- ☐ What is tcpdump?
- ☐ tcpdump vs Wireshark
- ☐ Interface capture
- ☐ Packet filtering
- ☐ Saving packet captures
- ☐ Headless-server troubleshooting

Example:

```
tcpdump -i eth0
```

DoS / DDoS

- ☐ DoS
- ☐ DDoS
- ☐ DoS vs DDoS
- ☐ Botnet
- ☐ Resource exhaustion
- ☐ Volumetric attacks
- ☐ Protocol attacks
- ☐ Application-layer attacks
- ☐ SYN Flood
- ☐ HTTP Flood

DoS	DDoS
Usually one source	Multiple sources
Smaller scale	Larger scale
Easier to block	More difficult to block

DDoS Mitigation

Layer 3/4:

- ACL
- Firewall
- SYN protection

- Rate limiting
- IPS

Layer 7:

- WAF
- CAPTCHA
- Request rate limiting
- Reverse proxy

Other:

- CDN
- Traffic scrubbing
- Cloud DDoS protection
- Load balancing

Reverse Proxy

- ☐ What is reverse proxy?
- ☐ Nginx reverse proxy
- ☐ Hide backend servers
- ☐ SSL/TLS termination
- ☐ Load balancing
- ☐ Caching
- ☐ Request filtering
- ☐ Security benefits



Forward Proxy vs Reverse Proxy

Forward Proxy	Reverse Proxy
Represents client	Represents server
Hides clients	Hides backend servers
Used by users	Used by applications
Squid commonly used	Nginx commonly used

Fail2ban

- ☐ What is Fail2ban?
- ☐ Reads authentication logs
- ☐ Detects repeated login failures
- ☐ Ban threshold
- ☐ Firewall integration
- ☐ SSH brute-force protection

```
Failed Login
  ↓
Authentication Log
  ↓
Fail2ban
  ↓
Threshold Reached
  ↓
Firewall Ban
```

SIEM & SOC

- ☐ What is SIEM?
- ☐ Log collection
- ☐ Log aggregation
- ☐ Log normalization
- ☐ Correlation
- ☐ Detection
- ☐ Alert generation
- ☐ Dashboards
- ☐ Incident investigation

SIEM Correlation Example

```
Firewall:
Repeated connections from IP X

      +

IDS:
Port scan from IP X

      +

Linux:
Multiple failed SSH logins

      ↓
```

SIEM Correlation



Possible Reconnaissance / Brute-Force Attack

Security Logs

- ☐ Firewall logs
- ☐ IDS/IPS logs
- ☐ Authentication logs
- ☐ System logs
- ☐ Application logs
- ☐ Web server logs
- ☐ VPN logs

SOC Workflow

Alert
↓
Triage
↓
Investigation
↓
Containment
↓
Eradication
↓
Recovery
↓
Reporting

Incident Response

Preparation
↓
Identification
↓
Containment
↓
Eradication
↓
Recovery
↓
Lessons Learned

Know:

- What happens in each phase
 - Short-term containment
 - Long-term containment
 - Root-cause analysis
 - Recovery validation
-

Threat Hunting

- ☐ What is threat hunting?
- ☐ Proactive vs reactive security
- ☐ Hypothesis
- ☐ Data collection
- ☐ Investigation
- ☐ Indicators
- ☐ Detection creation
- ☐ Response

```
Hypothesis
  ↓
Collect Data
  ↓
Search
  ↓
Investigate
  ↓
Validate
  ↓
Create Detection
  ↓
Respond
```

MITRE ATT&CK

- ☐ MITRE ATT&CK
- ☐ Tactics
- ☐ Techniques
- ☐ Procedures/TTPs

Important tactics:

- Initial Access
- Execution
- Persistence
- Privilege Escalation
- Defense Evasion

- Credential Access
 - Discovery
 - Lateral Movement
 - Collection
 - Command and Control
 - Exfiltration
 - Impact
-

Attack Symptoms

- ☐ High CPU
 - ☐ High RAM
 - ☐ High bandwidth usage
 - ☐ Service outage
 - ☐ Unexpected processes
 - ☐ Failed login attempts
 - ☐ Unexpected network connections
 - ☐ Changed files
 - ☐ Strange DNS requests
 - ☐ Large outbound traffic
-

Priority 2 — Important

Security Concepts

- ☐ Security Event
- ☐ Alert
- ☐ Incident
- ☐ Event vs Alert vs Incident
- ☐ QoS
- ☐ Bandwidth
- ☐ Latency
- ☐ Jitter
- ☐ Packet Loss
- ☐ Throughput
- ☐ Blast Radius
- ☐ Network Segmentation
- ☐ Three-Tier Architecture

Event → Alert → Incident

Example:

```
One failed login
  ↓
Event

100 failed logins
  ↓
Alert

Confirmed account compromise
  ↓
Incident
```

Network Segmentation

- ☐ Public Network
- ☐ DMZ
- ☐ Internal Network
- ☐ Database Network
- ☐ Management Network
- ☐ Limiting lateral movement
- ☐ Reducing blast radius

Three-Tier Architecture

```
Frontend
  ↓
Backend / Application
  ↓
Database
```

Security principle:

```
Internet → Frontend
Frontend → Backend
Backend → Database
```

The database should normally **not be directly exposed to the Internet**.

Firewalls & Filtering — Extended

- ☐ Proxy Firewall
- ☐ Screened Host Firewall

- ☐ UTM
 - ☐ UTM vs NGFW
 - ☐ GeoIP Blocking
 - ☐ IPv6 Firewall Rules
 - ☐ Xtables-Addons
 - ☐ Linux Kernel Modules for firewalling
 - ☐ Rate Limiting
-

UTM

Unified Threat Management may combine:

- Firewall
 - Antivirus
 - IDS/IPS
 - VPN
 - Web filtering
 - Content filtering
 - Anti-spam
-

NGFW

Know:

- Application awareness
 - Deep Packet Inspection
 - IDS/IPS
 - User awareness
 - Application control
 - Threat detection
-

GeoIP Blocking

- ☐ Country-based blocking
- ☐ Xtables-Addons
- ☐ Fraud reduction
- ☐ Region restrictions
- ☐ Limitations of GeoIP controls

GeoIP blocking is an additional control, not a complete security solution.

IPv6 Firewall Rules

- ☐ IPv6 firewalling
- ☐ `ip6tables`
- ☐ IPv4 vs IPv6 policy

- ☐ ICMPv6 importance
 - ☐ IPv6 exposure risk
-

Rate Limiting

Can be implemented using:

- iptables
- Nginx
- WAF
- Application layer
- API gateway

Used against:

- Brute force
 - DoS
 - DDoS
 - Excessive API requests
-

VPN Protocols — Extended

- ☐ PPTP
- ☐ SSTP
- ☐ L2TP
- ☐ Windows RRAS
- ☐ Hybrid VPN
- ☐ Trusted VPN
- ☐ Secure VPN
- ☐ VPN attacks
- ☐ VPN misconfiguration

PPTP

- Legacy VPN
- Weak security
- Generally avoided in modern secure deployments

SSTP

- Secure Socket Tunneling Protocol
- Uses TLS
- Common in Microsoft environments
- TCP 443

L2TP

- Layer 2 Tunneling Protocol

- Provides tunneling
- Usually combined with IPsec

RRAS

Routing and Remote Access Service:

- Routing
- VPN
- Remote access

VPN Attacks

- ☐ Credential theft
- ☐ Credential reuse
- ☐ Weak passwords
- ☐ Brute force
- ☐ Outdated VPN software
- ☐ Unpatched gateways
- ☐ Certificate issues
- ☐ Misconfiguration

IDS Architecture — Extended

- ☐ OSSEC
- ☐ IDS Architecture
- ☐ IDS Sensor
- ☐ IDS Agent
- ☐ IDS Manager
- ☐ Intruder Types
- ☐ Traditional vs Distributed attacks

```
Network / Host
  ↓
Sensor / Agent
  ↓
IDS Manager
  ↓
Database
  ↓
Console / Dashboard
```

OSSEC

- ☐ HIDS

- ☐ Log monitoring
 - ☐ File integrity monitoring
 - ☐ Agent/server architecture
 - ☐ Security alerts
-

Intruder Types

Masquerader

Unauthorized person pretending to be a legitimate user.

Misfeasor

Legitimate user abusing their authorized privileges.

Clandestine User

Attacker who gains administrative control and hides their activity.

Traditional vs Distributed Attacks

Traditional:

Attacker → Victim

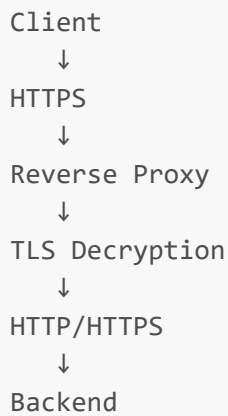
Distributed:

Bot 1 ┘
Bot 2 ┴→ Victim
Bot 3 ┘

Reverse Proxy & Load Balancing — Extended

- ☐ Load Balancer
 - ☐ Health checks
 - ☐ High Availability
 - ☐ Scalability
 - ☐ Squid
 - ☐ Nginx
 - ☐ SSL/TLS Termination
 - ☐ Server Farming
 - ☐ WAF vs Firewall
-

SSL/TLS Termination



Benefits:

- Central certificate management
- Reduced TLS processing on backend
- Easier load balancing
- Security inspection

Server Farming

- Multiple servers provide same service
- Load balancer distributes traffic
- Improves availability
- Improves scalability

WAF vs Firewall

Network Firewall	WAF
Mainly L3/L4	Mainly L7
IPs and ports	HTTP requests
Network attacks	Web application attacks
TCP/UDP filtering	SQLi, XSS etc.

ELK Stack

Elasticsearch

- Stores logs
- Searches/indexes logs

Logstash

- Collects logs
- Parses/processes logs
- Sends logs to Elasticsearch

Kibana

- Dashboards
- Visualization
- Searching
- Threat hunting

```
Logs
↓
Logstash
↓
Elasticsearch
↓
Kibana
```

Syslog

- ☐ Centralized logging
- ☐ Log forwarding
- ☐ Network devices
- ☐ Linux servers
- ☐ Firewalls
- ☐ Routers

Nagios

- ☐ Infrastructure monitoring
- ☐ Host monitoring
- ☐ Service monitoring
- ☐ CPU
- ☐ RAM
- ☐ Disk
- ☐ Availability
- ☐ Alerts
- ☐ Email notifications

Nagios vs SIEM

Nagios	SIEM
Infrastructure monitoring	Security monitoring

Nagios	SIEM
CPU/RAM/Disk	Security events
Availability	Attack detection
Operational alerts	Security alerts

Nagios vs IDS

Nagios → Is the system healthy?

IDS → Is malicious activity happening?

Priority 3 — Good to Know

Frameworks & Risk

- ☐ NIST Cybersecurity Framework
- ☐ OWASP Top 10
- ☐ Security breach case studies
- ☐ Financial impact
- ☐ Reputational impact

NIST CSF

Govern
Identify
Protect
Detect
Respond
Recover

OWASP Top 10 — Risk Perspective

Know broadly:

- Broken Access Control
- Cryptographic Failures
- Injection
- Insecure Design
- Security Misconfiguration
- Vulnerable and Outdated Components
- Identification and Authentication Failures

- Software and Data Integrity Failures
- Security Logging and Monitoring Failures
- SSRF

Focus on how these controls can help:

- Firewall
- WAF
- IDS/IPS
- SIEM
- Reverse Proxy

Security Breach Case Study

Analyze:

```
Attack Vector
  ↓
Vulnerability
  ↓
Root Cause
  ↓
Impact
  ↓
Countermeasure
```

Impact may include:

- Financial loss
- Downtime
- Legal penalties
- Incident response cost
- Customer loss
- Reputation damage

Firewall Misconfiguration

Examples:

```
0.0.0.0/0 → Database Port
```

```
ALLOW ANY → ANY
```

Risks:

- Unnecessary exposure
 - Increased attack surface
 - Unauthorized access
 - Data exposure
-

Firewall Automation

Use Bash/scripts to:

- Add rules
- Remove rules
- Block IPs
- Configure policies
- Apply repeated configurations

Also know risks:

- Incorrect automated rule
 - Lockout
 - Overly broad access
 - Lack of testing
-

Packet & Protocol Analysis

- ☐ Kerberos packet analysis
- ☐ TLS packet analysis
- ☐ Suspicious packet patterns

Kerberos

Know:

- Authentication protocol
- Ticket-based
- Common with Active Directory

TLS

Know:

- Client Hello
- Server Hello
- Certificate
- Key establishment
- Encrypted application traffic

Suspicious Patterns

- SYN scan
 - Excessive SYN traffic
 - ICMP flood
 - Sequential port scanning
 - Repeated failed connections
 - Strange DNS queries
-

Honeypot & Honeynet

Honeypot

A decoy system designed to attract attackers.

Honeynet

A network containing multiple honeypots.

Used to:

- Study attackers
 - Capture techniques
 - Identify malware
 - Improve detection
-

IDS Evasion

Attackers may try:

- Fragmentation
- Encoding
- Obfuscation
- Encryption
- Protocol manipulation

Defensive controls:

- Packet normalization
 - Reassembly
 - Updated signatures
 - Endpoint monitoring
 - TLS visibility
 - Layered detection
-

False Positive vs False Negative

False Positive

IDS says attack occurred



No real attack

False Negative

Attack actually occurred



IDS missed it

False negatives are usually more dangerous.

Security Event Severity

- Informational
- Low
- Medium
- High
- Critical

Severity depends on:

- Impact
- Asset importance
- Exploitability
- Threat
- Confidence
- Business criticality

Threat Intelligence

- ☐ IP reputation
- ☐ Malicious domains
- ☐ File hashes
- ☐ Attack techniques
- ☐ IOC
- ☐ IOA

IOC — Indicator of Compromise

Examples:

- Malicious IP
- Malicious domain

- Suspicious file hash
- Unknown process
- Strange login
- Unexpected network connection

IOA — Indicator of Attack

Focuses on attacker behavior.

Example:

```
PowerShell
  ↓
Downloads File
  ↓
Creates Persistence
  ↓
External Connection
```

QoS Security Analysis

```
DDoS Traffic ↑
  ↓
Congestion ↑
  ↓
Latency ↑
  ↓
Packet Loss ↑
  ↓
Service Quality ↓
```



Scenario-Based Interview Questions

Use this answer pattern for most scenarios:

```
Identify
  ↓
Investigate
  ↓
Contain
  ↓
Fix
  ↓
```

```
Monitor
  ↓
Prevent Recurrence
```

● Priority 1 — Must-Know Scenarios

Security Fundamentals — Scenarios

- ☐ A company server has an open SSH port and weak passwords. Identify the threat, vulnerability, risk, attack vector, and countermeasure.
- ☐ A critical server is compromised. How would defence in depth reduce the damage?
- ☐ A vulnerability exists but there is no easy way to exploit it. Is the risk automatically critical? Explain using likelihood and impact.
- ☐ An attacker compromises one employee account. How would you reduce the blast radius?

Firewall — Scenarios

- ☐ Your firewall has an **ALLOW ANY ANY** rule. What is the security risk and how would you fix it?
- ☐ A legitimate application stopped working after a firewall rule was added. How would you troubleshoot it?
- ☐ Users can browse the Internet, but unsolicited inbound connections must be blocked. What configuration is required?
- ☐ A firewall allows a reply packet only because it belongs to an already-established connection. What firewall feature is being used?
- ☐ You want only **192.168.1.10** to SSH to a Linux server. How would you configure the rules?
- ☐ Your firewall suddenly starts dropping legitimate HTTPS traffic. What would you check first?

DMZ — Scenarios

- ☐ A public web server must be accessible from the Internet, but the database must remain private. How would you design the network?

```
Internet
  ↓
Firewall
  ↓
DMZ
  ↓
Web Server
```

↓
Internal Firewall
↓
Database

- ☐ A web server in the DMZ is compromised. How do you prevent the attacker from reaching the internal database?
- ☐ What traffic would you allow between Internet → DMZ, DMZ → Internal, and Internal → DMZ?

iptables — Scenarios

- ☐ A packet reaches a Linux firewall. Explain how iptables decides whether to ACCEPT, DROP, or REJECT it.
- ☐ A Linux machine is routing traffic between two networks. Which chain is mainly used?

Answer: FORWARD

- ☐ An iptables rule looks correct but is never hit. What would you check?

Check:

- Rule order
- Correct chain
- Source/destination
- Protocol
- Port
- Packet counters
- Default policy
- ☐ You need to restrict repeated connections to SSH. How could rate limiting help?

NAT / Port Forwarding — Scenarios

- ☐ An internal web server is 192.168.1.10:80, but Internet users need to access it through the firewall's public IP. What would you configure?

Answer:

DNAT / Port Forwarding

Public-IP:80



192.168.1.10:80

- ☐ **Multiple internal users share one public IP for Internet access. Which NAT mechanism is being used?**

Explain:

- SNAT
- PAT
- MASQUERADE when appropriate

IDS / IPS — Scenarios

- ☐ **The company wants visibility into attacks but does not want the system to automatically block traffic. IDS or IPS?**

Answer: **IDS**

- ☐ **The company wants malicious network packets to be automatically dropped. IDS or IPS?**

Answer: **IPS**

- ☐ **Snort generates an alert but there was no real attack. What is this called?**

Answer: **False Positive**

- ☐ **An attacker successfully compromises the system but IDS generates no alert. What is this called?**

Answer: **False Negative**

- ☐ **You need to detect unauthorized modification of `/etc/passwd`. Would you use NIDS or HIDS?**

Answer: **HIDS**

- ☐ **You need to inspect packets flowing through a network segment. NIDS or HIDS?**

Answer: **NIDS**

- ☐ **Your signature-based IDS detects known attacks but misses a new attack. What additional detection method could help?**

Answer: **Anomaly-based detection**

- ☐ **Suricata is placed inline and starts dropping malicious traffic. What role is it performing?**

Answer: **IPS**

VPN / IPsec — Scenarios

- ☐ **Employees work from home and need secure access to internal servers. Which VPN type would you use?**

Answer: **Remote Access VPN**

- ☐ **Two branch offices must communicate securely over the Internet. Which VPN type?**

Answer: **Site-to-Site VPN**

- ☐ **All traffic from a remote employee must go through the corporate VPN. Which mode?**

Answer: **Full Tunnel**

- ☐ **Only corporate traffic should use the VPN, while normal Internet traffic goes through the user's ISP. Which mode?**

Answer: **Split Tunnel**

- ☐ **A site-to-site IPsec VPN connects two gateways. Tunnel mode or Transport mode?**

Answer: **Tunnel Mode**

- ☐ **You need both encryption and integrity with IPsec. AH or ESP?**

Answer: **ESP**

- ☐ **VPN authentication works, but users cannot reach one internal subnet. What would you check?**

Check:

- VPN routes
- Internal routes
- Firewall rules
- NAT
- IP forwarding
- Return route
- VPN policy
- ☐ **Attackers are using leaked passwords against VPN accounts. What security controls would you apply?**

Explain:

- MFA
- Strong passwords
- Rate limiting
- Account lockout
- Monitoring

- Disable compromised credentials

Wireshark / tcpdump — Scenarios

- ☐ **Users report that a website is very slow. How would Wireshark help?**

Check:

```
DNS Resolution
  ↓
TCP Handshake
  ↓
TLS Handshake
  ↓
HTTP Request/Response
  ↓
Retransmissions / Packet Loss
```

- ☐ **You captured 10,000 packets and only want to see DNS traffic. What would you use?**

```
dns
```

- ☐ **You only want to capture HTTPS traffic from the start. Capture filter or Display filter?**

Answer: **Capture Filter**

- ☐ **You see thousands of SYN packets but very few completed TCP handshakes. What attack might this indicate?**

Answer: **SYN Flood**

- ☐ **A website is not opening. What packet-level troubleshooting order would you follow?**

```
DNS
  ↓
TCP
  ↓
TLS
  ↓
HTTP
```

- ☐ **When would you prefer tcpdump over Wireshark?**

Example:

- Remote Linux server

- No GUI
- SSH troubleshooting
- Lightweight packet capture

DoS / DDoS — Scenarios

- ☐ A website receives huge traffic from one attacker and goes down. DoS or DDoS?

Answer: **DoS**

- ☐ A website receives attack traffic from thousands of different systems. What do you suspect?

Answer: **DDoS**

- ☐ You see thousands of SYN packets with very few ACKs. What attack is likely?

Answer: **SYN Flood**

- ☐ A login endpoint receives thousands of HTTP requests per second. Which type of attack?

Answer: **Layer 7/Application-layer DoS/DDoS**

- ☐ How would you mitigate a DDoS attack?

```
Firewall / ACL
  ↓
Rate Limiting
  ↓
IPS
  ↓
Reverse Proxy / WAF
  ↓
CDN
  ↓
Cloud DDoS Protection
```

- ☐ Why might blocking a single IP not stop a DDoS attack?

Because traffic may originate from thousands of distributed systems/bots.

Reverse Proxy / Load Balancer — Scenarios

- ☐ Nginx receives requests from users and forwards them to backend application servers. What role is it performing?

Answer: **Reverse Proxy**

- ☐ Why would you place Nginx in front of backend servers?

Explain:

- Hide backend
- TLS termination
- Load balancing
- Rate limiting
- Caching
- Request filtering
- ☐ **You have three backend servers. One becomes unhealthy. How should the load balancer react?**

Answer:

Stop forwarding new requests to the failed server and route traffic to healthy servers.

- ☐ **You want certificates managed in one place rather than on every backend. What should you configure?**

Answer: **TLS termination**

Fail2ban — Scenarios

- ☐ **SSH logs show hundreds of failed login attempts from one IP. How would Fail2ban help?**

```
Failed SSH Attempts
    ↓
Authentication Logs
    ↓
Fail2ban Detects Threshold
    ↓
Firewall Rule Added
    ↓
IP Blocked
```

- ☐ **Fail2ban accidentally blocks a legitimate administrator. What would you check?**

Check:

- Jail configuration
 - `maxretry`
 - `findtime`
 - `bantime`
 - Authentication logs
 - Ignore/allow list
-

SIEM / SOC — Scenarios

- ☐ **Firewall logs show repeated connections, IDS shows a port scan, and Linux logs show failed SSH attempts from the same IP. How would SIEM help?**

```
Firewall Alert
  +
IDS Alert
  +
Linux Login Failure
  ↓
SIEM Correlation
  ↓
Higher-Confidence Security Alert
```

- ☐ **Your SIEM receives millions of events per day. How does it detect attacks?**

```
Collection
  ↓
Parsing
  ↓
Normalization
  ↓
Correlation
  ↓
Detection
  ↓
Alert
```

- ☐ **A SIEM alert is generated for suspicious authentication. What should a SOC analyst do first?**

Explain:

1. Validate alert
2. Check affected user/host
3. Check source IP
4. Review authentication logs
5. Check related alerts
6. Decide false/true positive
7. Escalate if needed

- ☐ **A critical server has been compromised. Explain your incident response process.**

```
Identification
  ↓
Containment
  ↓
Eradication
  ↓
```

Recovery



Lessons Learned

- ☐ **An employee account logs in from an unusual location and immediately downloads sensitive files. What would you investigate?**

Check:

- Authentication logs
- VPN logs
- Source IP
- Login history
- Device information
- File access logs
- SIEM alerts
- Data transfer
- ☐ **A server suddenly shows high CPU, strange outbound connections, and unknown processes. What would you do?**

Explain:

Investigate



Check Processes



Check Network Connections



Check Logs



Check IDS/SIEM



Isolate if Compromised



Contain



Remediate

Threat Hunting / MITRE ATT&CK — Scenarios

- ☐ **No security alert exists, but you suspect attackers are using PowerShell to download malicious files. How would you perform threat hunting?**

```
Create Hypothesis
  ↓
Collect PowerShell / Endpoint Logs
  ↓
Search Suspicious Commands
  ↓
Check Network Connections
  ↓
Investigate
  ↓
Create Detection Rule
```

- ☐ **A threat hunter suspects credential dumping. What logs/data should be investigated?**

Examples:

- Endpoint telemetry
- Windows events
- Process creation
- Authentication logs
- Security tools
- Memory/security alerts
- ☐ **You observe Initial Access → Credential Theft → Lateral Movement → Exfiltration. How would MITRE ATT&CK help?**

It helps map attacker behavior to:

- Tactics
- Techniques
- Detection opportunities
- Mitigations

Priority 2 — Important Scenarios

Architecture / Segmentation

- ☐ **A compromised frontend server can directly access the database and management systems. What problem do you see?**

Explain:

- Weak segmentation

- Large blast radius
- Excessive network access
- ☐ **How does network segmentation reduce lateral movement?**
- ☐ **In a three-tier application, which communications should normally be allowed?**

Internet → Frontend

Frontend → Backend

Backend → Database

Avoid:

Internet → Database

- ☐ **Users report poor VoIP quality. Which QoS parameters would you check?**

Answer:

- Latency
- Jitter
- Packet loss
- Bandwidth

UTM / NGFW — Scenarios

- ☐ **An organization wants firewall, VPN, antivirus, IDS/IPS, and web filtering in one device. What solution fits?**

Answer: **UTM**

- ☐ **A company wants application-aware firewall rules and DPI. What would you recommend?**

Answer: **NGFW**

- ☐ **A company blocks traffic from countries where it has no customers. What control is being used?**

Answer: **GeoIP Blocking**

- ☐ **Attackers continue attacking through VPN/cloud addresses after GeoIP blocking. What does this show?**

GeoIP should only be one layer in defence in depth.

IPv6 Firewall Scenario

- ☐ **A server is properly protected using IPv4 firewall rules but unexpectedly accessible over IPv6. What could be wrong?**

Answer:

IPv6 firewall policy was not configured correctly.

Rate Limiting Scenario

- ☐ **Thousands of requests are hitting /login, but you cannot block all users. What would you configure?**

Answer:

- Rate limiting
 - Per-IP/request limits
 - WAF
 - CAPTCHA where appropriate
-

VPN Protocol Scenarios

- ☐ **A company is still using PPTP. What security concern would you raise?**

It is a legacy VPN technology with weak security and should generally be replaced.

- ☐ **A Microsoft environment needs a VPN that works over TCP 443. Which protocol could be used?**

Answer: **SSTP**

- ☐ **L2TP is configured without IPsec. What's missing?**

Strong encryption/security protection.

- ☐ **A full-tunnel VPN user cannot access a local network printer. What could explain it?**

Full-tunnel routing/policy may be sending or blocking local network traffic.

IDS Architecture Scenarios

- ☐ **A host agent finds an unauthorized system file change. Which component receives and manages the alert?**

Answer: **IDS/HIDS Manager**

- ☐ **An authorized employee steals data using legitimate access. Which intruder type?**

Answer: **Misfeasor**

- ☐ An unauthorized person pretends to be a legitimate user. Which intruder type?

Answer: **Masquerader**

- ☐ An attacker gains admin control and hides their activity. Which intruder type?

Answer: **Clandestine User**

ELK / Syslog Scenarios

- ☐ You need firewall, Linux, IDS and application logs in one place. What can be used?

```
Sources
  ↓
Syslog / Log Forwarder
  ↓
Central Log Platform / SIEM
```

- ☐ You need to search and visualize millions of logs. Explain ELK.

```
Logstash → Collect/Process
Elasticsearch → Store/Search
Kibana → Visualize
```

Nagios Scenarios

- ☐ A Linux server's disk usage reaches 95%. Which tool is likely to detect this first: Nagios or Snort?

Answer: **Nagios**

- ☐ Nagios reports a service is DOWN. Does that automatically mean the server was attacked?

Answer: No.

It may be:

- Application failure
- Network problem
- Resource exhaustion
- Maintenance
- Misconfiguration
- Security incident

Investigation is required.

WAF Scenario

- ☐ **A web application receives SQL injection requests. Would a normal network firewall or WAF be more useful?**

Answer: **WAF**, because it understands HTTP/application-layer requests.

Priority 3 — Good-to-Know Scenarios

NIST Scenario

- ☐ **A company wants a framework covering Govern, Identify, Protect, Detect, Respond and Recover. Which framework would you suggest?**

Answer: **NIST Cybersecurity Framework**

Breach Analysis Scenario

- ☐ **Your manager asks you to analyze a security breach. What information would you collect?**

```
Attack Vector
  ↓
Vulnerability Exploited
  ↓
Root Cause
  ↓
Financial Impact
  ↓
Reputational Impact
  ↓
Countermeasures
```

Firewall Misconfiguration Scenario

- ☐ **A database port is open to 0.0.0.0/0. What is the risk?**

Explain:

- Internet exposure
 - Larger attack surface
 - Brute-force attempts
 - Exploitation
 - Unauthorized database access
-

Firewall Automation Scenario

- ☐ **A team manually manages hundreds of iptables rules. Should they automate them?**

Benefits:

- Consistency
- Speed
- Repeatability

Risks:

- Bad script can lock out systems
 - Wrong rules can be deployed everywhere
 - Testing/version control required
-

Packet Analysis Scenario

- ☐ **Wireshark shows connections to ports 20, 21, 22, 23, 25, 53, 80, 110 etc. sequentially from the same IP. What might be happening?**

Answer: **Port Scan**

- ☐ **You can see a TLS handshake in Wireshark but cannot read the HTTP application payload. Why?**

Because TLS encrypts the payload.

IDS Evasion Scenario

- ☐ **An attacker fragments packets or obfuscates content to avoid IDS detection. What is this technique?**

Answer: **IDS Evasion**

Mitigations:

- Packet normalization
 - Reassembly
 - Updated rules
 - Endpoint monitoring
 - Multiple security layers
-

Honeypot Scenario

- ☐ **You intentionally deploy a fake SSH server to attract attackers. What is it?**

Answer: **Honeypot**

- ☐ **You deploy several decoy servers forming a fake network. What is it?**

Answer: **Honeynet**

IOC / IOA Scenarios

- ☐ A compromised system connects to a known malicious IP. Is the IP an IOC or IOA?

Answer: **IOC**

- ☐ You observe PowerShell downloading a file, creating persistence and connecting externally. What type of indicator is this?

Answer: **IOA**, because it represents attacker behavior.

QoS / DDoS Scenario

- ☐ During a DDoS attack, latency and packet loss rise sharply. Why?

Because attack traffic consumes:

- Bandwidth
- Connection capacity
- Network resources
- Server resources

Result:

```
Traffic ↑  
↓  
Congestion ↑  
↓  
Latency ↑  
↓  
Packet Loss ↑  
↓  
Service Quality ↓
```



Practical / Lab Scenario Questions

iptables Lab

- ☐ How would you allow SSH from one IP only?
- ☐ How would you block a specific IP?
- ☐ How would you block a port?
- ☐ How would you allow established connections?
- ☐ How would you configure FORWARD rules?
- ☐ How would you configure DNAT?

- ☐ How would you configure SNAT?
- ☐ How would you use MASQUERADE?
- ☐ How would Linux share Internet access?
- ☐ How would you verify iptables rules?
- ☐ How would you check packet counters?
- ☐ A valid rule doesn't work. How do you troubleshoot it?

Example thought process:

```
Correct Table?
↓
Correct Chain?
↓
Correct Rule Order?
↓
Correct IP/Port?
↓
Packet Counter Increasing?
↓
Default Policy?
```

Wireshark Lab

- ☐ Capture TCP traffic.
- ☐ Identify SYN/SYN-ACK/ACK.
- ☐ Filter DNS traffic.
- ☐ Filter HTTP traffic.
- ☐ Filter ICMP traffic.
- ☐ Identify a SYN flood.
- ☐ Identify repeated DNS queries.
- ☐ Identify suspicious port scanning.
- ☐ Identify retransmissions.
- ☐ Explain capture vs display filters.

tcpdump Lab

- ☐ Capture packets from a specific interface.
- ☐ Capture traffic for a port.
- ☐ Save traffic to `.pcap`.
- ☐ Open the capture later in Wireshark.
- ☐ Explain when tcpdump is more useful than Wireshark.

Fail2ban Lab

- ☐ Explain Fail2ban installation.

- ☐ Explain Jail configuration.
 - ☐ Explain how Fail2ban reads SSH logs.
 - ☐ Explain `maxretry`.
 - ☐ Explain `findtime`.
 - ☐ Explain `bantime`.
 - ☐ Explain firewall integration.
 - ☐ Legitimate user is banned — how do you troubleshoot?
-

Nginx / Squid Lab

- ☐ Explain Nginx reverse proxy configuration.
 - ☐ Explain backend forwarding.
 - ☐ Explain load balancing.
 - ☐ Explain SSL termination.
 - ☐ Explain regex URL routing.
 - ☐ Explain Squid.
 - ☐ Forward Proxy vs Reverse Proxy.
 - ☐ What happens if one backend goes down?
-

OpenVPN Lab

- ☐ Explain OpenVPN installation.
- ☐ Explain certificates.
- ☐ Explain server configuration.
- ☐ Explain client configuration.
- ☐ Explain site-to-site VPN.
- ☐ Tunnel is UP but remote hosts cannot communicate. What would you check?

Check:

```
VPN Status
  ↓
Routes
  ↓
Firewall
  ↓
IP Forwarding
  ↓
NAT
  ↓
Return Route
```

Snort Lab

- ☐ Explain Snort installation.

- ☐ Explain Snort configuration.
 - ☐ Explain Snort NIDS mode.
 - ☐ Explain Snort rule syntax.
 - ☐ Write a basic ICMP rule.
 - ☐ Write a basic HTTP rule.
 - ☐ Detect port scanning.
 - ☐ Explain Snort alerts.
 - ☐ Snort detects but doesn't block — why?
-

Suricata Lab

- ☐ Explain Suricata installation.
 - ☐ IDS vs IPS mode.
 - ☐ Inline mode.
 - ☐ Rule configuration.
 - ☐ Alert/log analysis.
 - ☐ How does Suricata block traffic?
 - ☐ Suricata vs Snort.
-

OSSEC Lab

- ☐ Explain OSSEC.
 - ☐ HIDS architecture.
 - ☐ Agent/server communication.
 - ☐ Log monitoring.
 - ☐ File integrity monitoring.
 - ☐ OSSEC reports `/etc/passwd` changed — what would you investigate?
-

ELK Lab

- ☐ Elasticsearch role
- ☐ Logstash role
- ☐ Kibana role
- ☐ Log ingestion
- ☐ Searching
- ☐ Dashboard creation
- ☐ Threat hunting
- ☐ Detecting anomalies

Security Logs



Logstash



Elasticsearch



Kibana



Threat Investigation

Syslog / SIEM Lab

- ☐ Configure central Syslog server.
- ☐ Forward firewall logs.
- ☐ Forward Linux logs.
- ☐ Forward IDS logs.
- ☐ Correlate multiple events.
- ☐ Create alert conditions.

Scenario:

Firewall:

Connection from 10.10.10.5

IDS:

Port scan from 10.10.10.5

Linux:

Failed SSH login from 10.10.10.5



SIEM Correlation



Suspicious Reconnaissance + Brute Force

Nagios Lab

- ☐ Install Nagios.
- ☐ Configure Windows monitoring.
- ☐ Configure Linux monitoring.
- ☐ Monitor RAM.
- ☐ Monitor disk.
- ☐ Monitor CPU.
- ☐ Monitor host UP/DOWN.
- ☐ Configure email alerts.
- ☐ Configure warning and critical thresholds.

Scenario:

- ☐ Server is UP but RAM is 95%. What will Nagios report and what would you investigate?
 - ☐ Disk usage continuously increases. How would you configure alert thresholds?
 - ☐ How do you differentiate a monitoring problem from a security incident?
-



Top 25 Scenario Questions to Practice First

1. Web server public, database private — design DMZ.
2. Firewall has **ALLOW ANY ANY** — identify risk and fix it.
3. SSH brute-force attack — how would you detect and stop it?
4. Internal server needs public access — configure DNAT/port forwarding.
5. Internal systems share one public IP — explain SNAT/PAT/MASQUERADE.
6. Company wants alert-only detection — IDS or IPS?
7. Company wants automatic blocking — IDS or IPS?
8. When would you use NIDS vs HIDS?
9. Explain False Positive vs False Negative with a scenario.
10. Signature-based IDS misses a new attack — what can help?
11. Two offices need secure connectivity — design a site-to-site VPN.
12. Employee works from home — Remote Access VPN scenario.
13. Full Tunnel vs Split Tunnel scenario.
14. IPsec AH vs ESP scenario.
15. IPsec Tunnel Mode vs Transport Mode scenario.
16. Website is slow — troubleshoot using Wireshark.
17. Thousands of SYN packets — identify SYN flood.
18. Website receives traffic from thousands of IPs — DDoS mitigation.
19. Nginx in front of backend servers — explain reverse proxy.
20. One backend fails — how should load balancer react?
21. Firewall + IDS + Linux alerts from same IP — explain SIEM correlation.
22. Suspicious login detected — explain SOC triage.
23. Critical server compromised — explain incident response.

24. **Nagios vs IDS vs SIEM — which tool would you use for different situations?**

25. **A vulnerability exists but there is no easy way to exploit it — explain likelihood vs impact.**



Recommended Study Order

1. Vulnerability / Threat / Risk
2. Firewall
3. Stateless vs Stateful Firewall
4. DMZ
5. iptables
6. NAT / SNAT / DNAT / Port Forwarding
7. IDS vs IPS
8. NIDS vs HIDS
9. Signature vs Anomaly Detection
10. Snort
11. Suricata
12. OSSEC
13. VPN
14. IPsec
15. AH vs ESP
16. Tunnel vs Transport Mode
17. Full Tunnel vs Split Tunnel
18. Wireshark
19. tcpdump
20. DoS / DDoS
21. DDoS Mitigation
22. Reverse Proxy
23. Nginx
24. Fail2ban
25. SIEM
26. Log Correlation
27. ELK
28. Threat Hunting
29. SOC Workflow
30. Incident Response
31. MITRE ATT&CK
32. Nagios



Strongest-Answer Priority

For a fresher **Network / Security / Cloud / Infrastructure interview**, be strongest in:

Firewall
↓
DMZ

```
↓
iptables
↓
NAT
↓
IDS / IPS
↓
Snort / Suricata / OSSEC
↓
VPN
↓
IPsec
↓
Wireshark
↓
DoS / DDoS
↓
SIEM
↓
Log Correlation
↓
Defence in Depth
↓
Incident Response
```

Interview Answer Formula

For a normal technical topic:

```
What is it?
↓
How does it work?
↓
Why is it used?
↓
Real example
```

For a scenario question:

1. Identify the problem
2. Verify using logs/tools
3. Find the affected system
4. Contain the threat
5. Fix the root cause
6. Restore services safely

7. Monitor
8. Prevent recurrence

Important: In a scenario interview question, don't answer only with the name of a tool.

Example:

Bad answer:

"I will use Fail2ban."

Better answer:

"First I will check SSH authentication logs and confirm repeated failed login attempts. Then I will identify the attacking IP, use Fail2ban or firewall rules to block repeated attempts, harden SSH with key-based authentication and restricted access, and continue monitoring the logs to verify that the attack has stopped."

Related Notes

- [[00 - PGCP-ITISS Full Syllabus and Interview Checklist]]
- [[06 - Compliance Audit Syllabus and Interview Checklist]]